

Aspetos Socio-Profissionais da Informática

Socio-Professional Aspects of Computer Science

Kevin Gallagher

Today's class will be about *privacy* and *data regulation*.

*I will be going through different **regulations of privacy**, as well as their **implications** for developers. Most relevant to us, I will discuss the current data protection regulation, the **GDPR**, and how it **regulates data usage**.*

*This is a complex topic, and a lot of this material is going to be very **important in your future careers**. It's quite likely a lot of this content **will be on the test**.*

Privacy

A* Privacy Problem

* One of many

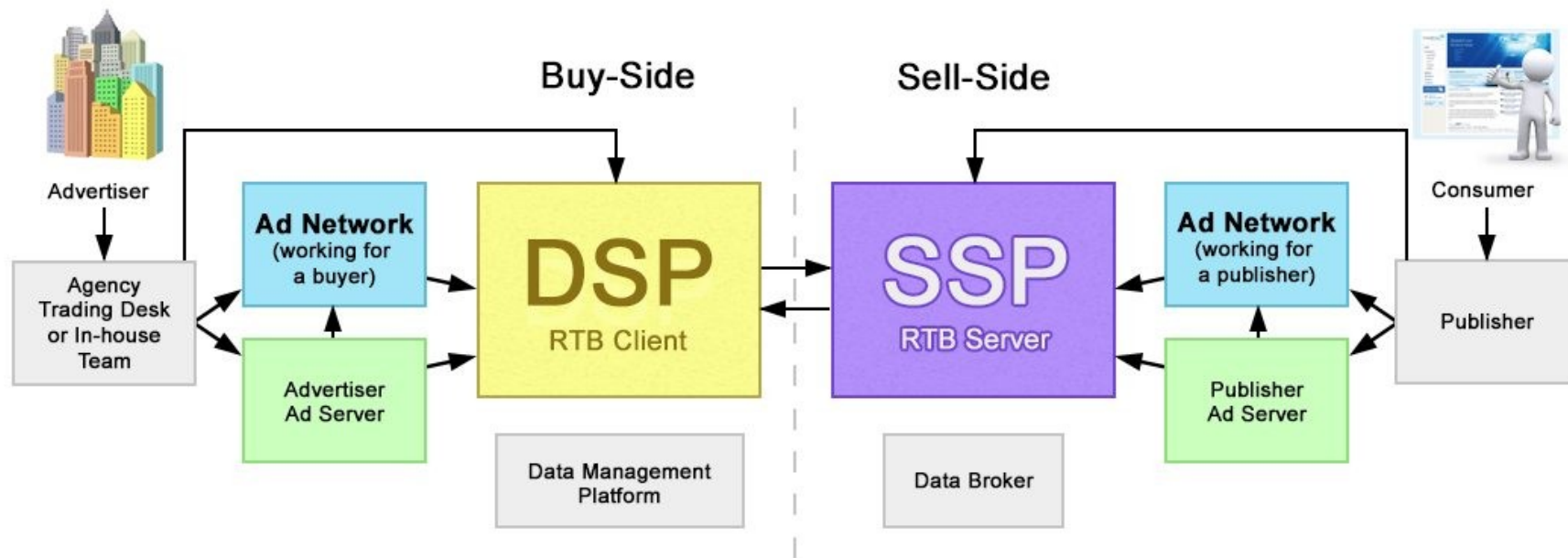
*You search for a **set of boots** online.*

*You decide not to buy them. They're **too expensive**.*

*Most of the **ads you see** on the next pages are **all about those boots**.*

*The current Internet is **not** designed to have privacy.*

Advertising on the Internet



Last time we discussed what privacy is. This time we will look at how privacy is **legally protected**.

Privacy by Policy: VPNs

- Privacy by Policy is:
 - Achieved by **trusting** a single entity
 - Not necessarily guaranteed by the technology alone
 - Can be **removed/changed** by a simple change of policy

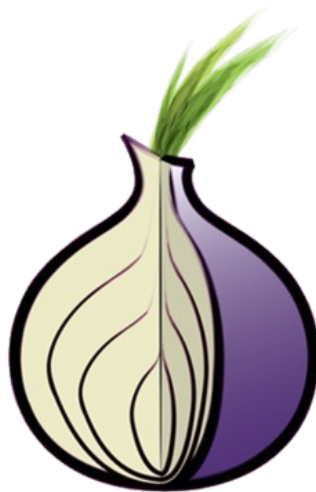
Privacy by Policy: VPNs



Privacy by Design: Tor

- Privacy by Design is:
 - **Guaranteed** by technology
 - **Cannot be revoked** without a change in the code
 - Does **not** require trust in a single given entity
 - Beyond sometimes trusting the correctness of the implementation

Privacy by Design: Tor



Privacy Through Data Minimization

- **Client-side** Data Minimization:
 - Block data from being collected in the first place
 - Creating clients that only require the bare minimum of data necessary
 - Can be privacy by design or privacy by policy

Privacy Through Data Minimization



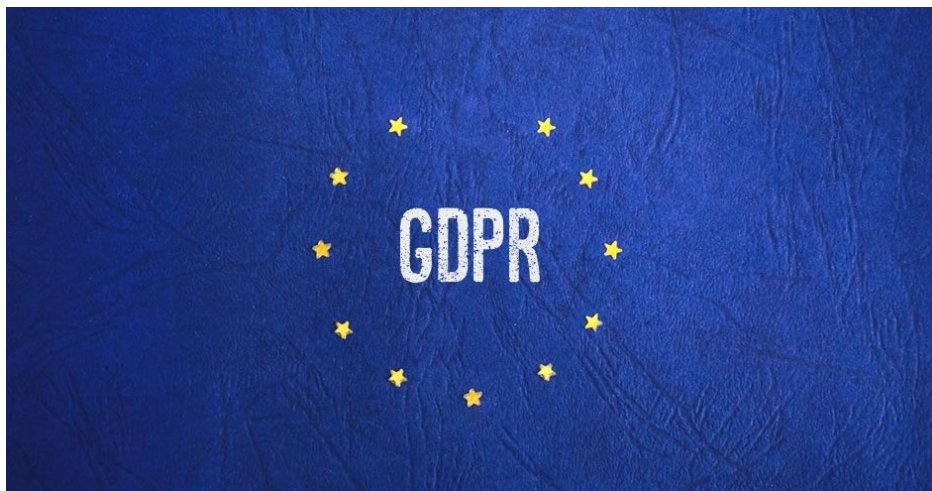
Privacy Through Data Minimization

- **Server-side** Data Minimization:
 - Decide not to collect/infer certain information
 - Do not store data after use when possible
 - Do not collect info when possible
 - Is privacy through policy

Privacy Through Data Minimization



Legally Protecting Data



General Data Protection Regulation

- Passed in 2016
- Is mostly an iteration on previous data protection regulations
- Is meant to:
 - Offer clear and predictable data **protection rights** to consumers and employees; and
 - Allow for **easier transfer of data** between EU Member states
- Focused on **data protection**, which is not just privacy.

General Data Protection Regulation

- Applies to:
 - Multiple Entities:
 - Data Controllers
 - Data Processors
 - Who are doing economic activity
 - Within the EU or with data from people in the EU.
- Is a general directive, so it is applied differently in different countries.

GDPR Definitions [1]

- Personal Data:
 - Data related to an **identified** or **identifiable natural person**
 - A natural person is considered identifiable if:
 - **Directly** or **indirectly identifiable** through an identifier or **combination of data points** held
- Data Processing:
 - “**any operation or set of operations which is performed on personal data or on sets of personal data**, whether or not by automated means, such as collection, recording, organisation, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction;”
 - Generally, if you have collected, stored, or accessed data in **any way**, it's processing.

GDPR Definitions [1]

- Data Controller:
 - “natural or legal person, public authority, agency or other body which, alone or jointly with others, **determines the purposes and means of the processing of personal data**; where the purposes and means of such processing are determined by Union or Member State law, the controller or the specific criteria for its nomination may be provided for by Union or Member State law;”
- Data Processor
 - “‘processor’ means a natural or legal person, public authority, agency or other body which **processes personal data** on behalf of the controller;”

GDPR Definitions [1]

- Third Party
 - “a natural or legal person, public authority, agency or body other than the data subject, controller, processor and persons who, under the **direct authority of the controller or processor**, are **authorised to process personal data**,”
- Consent
 - “any **freely given**, **specific**, **informed** and **unambiguous** indication of the data subject's wishes by which [they], by a statement or by a **clear affirmative action**, signifies **agreement** to the processing of personal data relating to him or her;”
 - Must be as **easy to revoke** consent as to give consent

GDPR: The Seven Principles

- Lawfulness, Fairness, and Transparency
 - Processing can occur if:
 - Data Subject **fully understands and consents**
 - To **fulfill a contract** with the data subject
 - To **fulfill a legal obligation**
 - For **safety** reasons
 - For a public task in the **public interest**
 - When the data owner or processor has an **interest** that:
 - Is **legitimate**, and
 - **Cannot be overridden** by rights of the data subject, and
 - Is **not objected to** by the data subject, or the **objection** can be **argued against**

GDPR: The Seven Principles

- Purpose Limitation:
 - Data must be collected and processed **only for the stated purposes**.
 - To process data for other reasons, **authorization is needed**.
- Data Minimization:
 - Only process the **minimum data** needed to meet the purposes
- Accuracy:
 - The quality and **accuracy of the data** that is processed must be guaranteed.
 - If the data is not accurate, the data subject has the right to **update the data**.

GDPR: The Seven Principles

- Storage Limitations:
 - Data **cannot** be held for **longer than is required**.
 - **Indefinite** storage is allowed in the case of:
 - Archiving for the **public interest**
 - Scientific or historical **research** purposes
 - **Statistical** purposes
- Integrity and Confidentiality:
 - The secure processing of data, i.e. **protecting the data** from data breaches or malicious edits
- Accountability:
 - Data Controllers and Data Processors must be able to **demonstrate compliance**
 - If there is an unauthorized disclosure, it must be reported and there need to have been reasonable safeguards against it.

GDPR: The Eight Rights

- Be informed
 - Clear, succinct, and easily understandable information about how data is processed
 - Name and contact of organization, representative, data protection officer
 - Purposes of collection and processing
 - Legitimate interests for processing
 - Retention periods
- Rectification
 - Correct incorrect data
 - Complete incomplete data
 - Can be done verbally or in writing
 - Requires a response in one month.

GDPR: The Eight Rights

- Access
 - Right to request **access to their own data**
 - Companies have **one month** to respond
 - **No fee** can be charged
 - Businesses must **verify the identity** of the requester
- Erasure
 - Right to request data be **erased**
 - Companies have **one month** to respond
 - Not absolute – if a **legal reason** is requiring the data to be held, it cannot be deleted.
 - **Marking for deletion** is OK as long as it is deleted in a **reasonable amount of time**.

GDPR: The Eight Rights

- Restrict processing of your data
 - Ask for the restriction or suppression of personal data.
 - Companies can store data, but **cannot process** it in any other way.
 - Not absolute.
 - Companies have **one month** to respond.
- Data Portability
 - **copy, transfer** or **move** personal data from one online environment to another, safely and securely
- Object
 - Right to object to their data being used for **marketing reasons**
 - Right to object to use of data for **other purposes**
 - If the company has a compelling reason to continue, it may.

GDPR: The Eight Rights

- Automated Profiling and Decision Making
 - If the processor is:
 - acting **solely** on automated decision-making, and
 - This decision-making has a **significant effect on the individual**
 - If so, the processor must:
 - Tell the subject about the processing
 - Have and communicate easy ways to **challenge automated decisions**
 - Ask for **humans to verify** the decision
 - **Check** the system regularly and often

Now that we understand the rights as they exist in the law, let's look at them from a **technical perspective**.

GDPR: The Eight Rights

- Be informed
 - Change logs about the use of data need to be written in a way that lay people understand
 - Ensure privacy policies match what is truly happening with data flow
- Rectification
 - Find incorrect data
 - Update incorrect data
 - Ensure corrections propagate.

GDPR: The Eight Rights

- Access
 - Discover all data for a given subject
 - What happens if databases are poorly designed or legacy?
 - Compile and summarize it:
 - in a way that is readable
 - potentially portable
 - Deliver it securely
 - TLS
 - Encrypted message

GDPR: The Eight Rights

- Erasure
 - Discover data to be deleted
 - Mark exceptions in the database
 - Decide on soft or hard deletion
 - Soft deletion: anonymize the data sufficiently
 - Hard deletion: delete the data
 - Propagate the deletion
 - Backups
 - Delete from the most recent backup, or
 - Keep a record of all deletions since most recent backup

GDPR: The Eight Rights

- Restrict processing of your data
 - **Discovering** related data that has been restricted.
 - Giving proper **metadata tags** to ensure the restrictions are actionable.
 - **Verifying** the metadata tags **before any processing** of data.
- Data Portability
 - **Aggregate** all data.
 - Create a **portable copy** of that data.
 - **Transfer** large amounts of data **securely**.
- Object
 - Give proper **metadata tags** before any processing of data.
 - **Verifying** the metadata tags **before any processing** of data.

GDPR: The Eight Rights

- **Automated Profiling and Decision Making**
 - Publish **understandable information** about automatic decision making
 - Have proper **metadata tags** for data impacted by **automated decisions**
 - Have proper **metadata tags** for **contested decisions**
 - Make sure related processing is **paused** in case of contesting.
 - Have a **platform** where people can escalate decisions to human review.

GDPR: Current Situation

- Requires **pseudonymisation** and **encryption** of data being processed
 - Not actually sufficient for privacy, but what the law requires
- **Cookie banners:**
 - A pop-up window in a site that asks for consent for data processing
 - Responses stored as **cookies**
 - A way of gaining a clear signal of **consent** for data processing
 - Allows for easy acceptance or rejection
- Problems with cookie banners:
 - Using **psychological tricks** to get people to select the “preferred” option
 - Often times don’t allow for a **Reject All**
 - Often times no option to **object** to processing

GDPR: Current Situation

- Problems with **cookie banners**:
 - What happens if I **don't click accept or reject**?
 - Some cookie banners set consent as the default option, when it **should be the contrary**
 - When looking at the detailed view, it isn't clear **how data is being used** by each partner
- Problems with **privacy policies**:
 - Often times still **opaque and confusing**.
- Problems with **GDPR in general**:
 - **Lack of enforcement**
 - **Dark Patterns**
 - UI designed to trick people into doing things

Blockchain is a distributed, append-only ledger that **permanently stores** information submitted to it. The only way to **remove** values from Blockchain is to get **51%** of the participating nodes to agree to **rewrite the Blockchain history**, which is costly.

Is Blockchain **legal** under GDPR?

How does the **right to be forgotten** interact with **data backups**?

How does a data owner determine **how long** they need to **retain** data for?

Is **mild improvement** in accuracy sufficient to justify **processing more data**?

Who determines whether or not a legitimate interest **outweighs** the **rights** of the data subject?

How do we know if a given form of **pseudonymization** is **sufficient**?

Is it **easy** to **revoke consent** on websites?

What are some **pros** of the GDPR?

What are some **cons** of the GDPR?

California Consumer Protection Act

- Passed in June, 2018
- Similar to GDPR, but with some **differences**.
- Is **motivated** more by privacy than the GDPR is.
 - This doesn't mean it protects privacy better.
- Applies to:
 - Any **for-profit business** that:
 - Have annual gross revenues of **25 Million USD**; or
 - Buys, sells, etc., personal information of **50.000 consumers, devices, or households annually**; or
 - Derives **50% or more of its profit** from selling consumers' personal information.
 - And:
 - Does business in **California**

CCPA Definitions [2]

- **Personal Information:**
 - Identifiers such as Name, IP Address, etc.
 - Commercial information
 - Property and product records and interests
 - Browsing/Internet history
 - Geolocation Data
 - Audio, electronic, visual, thermal, olfactory, or other information
 - Employment information
 - Non-public education information
 - Inferences drawn from any of the above information
 - Does **not** include publicly available information
 - “information lawfully made available from federal, state, or local government records

CCPA Definitions [2]

- **Probabilistic Identifier:**
 - “identification of a consumer or a device to a degree of certainty of more probable than not based on any categories of personal information included in, or similar to, the categories enumerated in the definition of personal information.”
- **Processing:**
 - “any operation or set of operations that are performed on personal data or on sets of personal data, whether or not by automated means.”
- **Consumer:**
 - “a natural person who is a California resident, as defined in Section 17014 of Title 18 of the California Code of Regulations, as that section read on September 1, 2017, however identified, including by any unique identifier”

CCPA Definitions [2]

- **Third Party:**
 - a person who is **not** any of the following:
 - The business that collects personal information from consumers under this title.
 - A person to whom the business discloses a consumer's personal information for a business purpose pursuant to a written contract, provided that the contract imposes specific limits [2]
- **Consent:**
 - Interestingly **not defined**.

CCPA: The Key Rights

- Right to **Know**
 - Consumers can **request a copy** of what is being shared
 - Organizations must notify the consumers of what is being shared on their website before or **at the point of** collection.
- Right to **Delete**
 - Businesses must **inform** about the right to delete
 - Must delete requested data, and **request service providers to do the same.**
 - Businesses can keep the info if it is **required** to:
 - Complete pending transactions for which it was collected
 - Detect security incidents, protect against or prosecute malicious activity
 - Debug errors
 - Exercise free speech (??) or other right provided by law

CCPA: The Key Rights

- Right to **Delete** (continued)
 - Businesses can keep the info if it is required to:
 - Compliance with other laws
 - Engage in peer-reviewed research in the public interest
 - To enable solely internal uses that are reasonably aligned with the expectations of the consumer based on the consumer's relationship with the business.
 - Otherwise use the consumer's personal information, internally, in a lawful manner that is compatible with the context in which the consumer provided the information
- Right to **Opt Out**
 - In contrast with the GDPR, the CCPA uses a weaker opt-out regime.
 - Except for minors, where it is opt-in
 - Consumers must be informed of the right to opt out.
 - Global Privacy Control signals must be obeyed.

CCPA: The Key Rights

- Right to **Correct**
 - Consumers have a right to **correct inaccurate information** being held about them.
- Right to **Limit**
 - Consumers have a right to ask business to **limit sensitive personal information use** to certain purposes
 - Fulfilling contract, providing service, etc.
- Right to **Non-discrimination**
 - Consumers who **exercise their CCPA rights** cannot be:
 - Charged higher prices
 - Denied services

What are the **differences** in implementing CCPA **in practice** compared to GDPR?

Is it **easier** or **harder**?

Any Questions?

References

- [1] <https://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=CELEX:32016R0679>
- [2] https://leginfo.legislature.ca.gov/faces/billTextClient.xhtml?bill_id=201720180AB375